CASE STUDY

The ConnectWise Cloud Backup Compromise of October 2026: A Case Study

A TeamStarWolf case study. Published 12 November 2026; sources checked 11 November 2026; the ConnectWise, Microsoft and Huntress primaries reopened 12 November 2026.

Executive summary

The people this reached were managed service providers (MSPs) and the businesses whose Microsoft 365 tenants they back up. Many of those tenants had granted ConnectWise Cloud Backup (formerly SkyKick) broad standing permissions, since the tool needs wide access to mailboxes and files [9] (**Reported**); Microsoft describes the compromised application as having high privileges [2] (**Confirmed**). In mid-October 2026 an application credential that lived in ConnectWise's own tenant was compromised and used to sign in as that multi-tenant application to customer tenants and obtain Microsoft Graph tokens [3] (**Confirmed**). The sign-ins were app-only, so no user signed in and user multi-factor authentication (MFA) never came into play [2] [3] (**Confirmed**).

Microsoft says the actor used ARTEX to attempt sign-ins to more than 2,250 tenants, but does not say how many were compromised, and says a successful authentication does not by itself show data access [2] (**Confirmed**). Huntress, watching its own customers, confirmed unauthorized sign-ins in 162 tenants on 16 October and found post-compromise activity in two of more than 10,000 tenants it reviewed [3] (**Confirmed**). Microsoft assesses that Storm-0940, a China-state aligned actor, was responsible, and that it used the open-source agentic AI framework ARTEX; no confidence level is given [2] (**Confirmed** as Microsoft's assessment). No CVE applies: this was abuse of an application identity, not a software flaw [2] [8] (**Confirmed**).

Key facts at a glance

Field	Value
Vendor	ConnectWise; product Cloud Backup (formerly SkyKick), plus the Cloud Management and SaaS Security services [1]
What was abused	Application credentials for ConnectWise's multi-tenant Microsoft 365 apps; Huntress lists seven app identities, including Cloud Backup `506e08f9-6e9a-4da4-942b-a099a03644ae` [3]
Main activity window	15 October 2026, from 03:44 UTC (01:58 UTC if the role self-assignments in about 50 tenants were not vendor automation) to the last confirmed sign-in at 08:44 UTC, then a targeted wave to 14:20 UTC [3]
Reach	Sign-ins attempted to more than 2,250 tenants (Microsoft) [2]; 162 tenants with confirmed unauthorized sign-ins (Huntress, 16 Oct) [3]
Confirmed post-compromise activity	Two tenants in Huntress's review [3]; "multiple customer environments" in Microsoft's [2]
Attribution	Microsoft: Storm-0940, China-state aligned, no confidence level stated [2]; ConnectWise: "appears" to be a China state-aligned group [1]; Huntress: not independently verified [4] [5]
Tooling	ARTEX, an open-source multi-agent LLM penetration-testing framework [2]
CVE and KEV	None applies; no KEV entry for Cloud Backup or SkyKick as of catalog 2026.11.10 [8]

Key findings

- **The trust was the attack surface.** The attacker did not break into customer tenants; it used permissions customers had already granted a backup vendor, and, per The Record, Microsoft said the actors likely abused elevated permissions such as Directory.ReadWrite.All [9] (**Confirmed**; **Reported** for the named permission).
- **Persistence was planted on other apps.** In one tenant a ConnectWise app gave itself Global Administrator and a script added client secrets, set to expire in 2028, to two other applications, one of them Huntress's own [3] (**Confirmed**). ConnectWise notes that access established through separate identities needs its own review and remediation [1] (**Confirmed**).
- **The record is quieter than the headlines.** "2,250 compromised" and "thousands of companies" conflate tenants targeted with tenants compromised [2] [11] (**Inferred**). Graph directory reads do not appear in the audit logs [3], so "nothing visible taken" is not "nothing taken" [3] (**Confirmed**).
- **Speed came from automation.** Microsoft's Figure 1 shows over 200 sign-ins in under four minutes using four application credentials, and, across the wider ARTEX campaign, multiple cases of under three hours from targeting to privileged access [2] (**Confirmed**).
- **Restoration was still incomplete after nearly three weeks.** ConnectWise rebuilt the service around a new app and required every partner to re-authorize each tenant; dashboards and billing were still being restored on 4 November [1] (**Confirmed**).

Top recommendations

1. Inventory every multi-tenant app with standing Graph permissions in your tenant, by application ID, and cut each to the least privilege it needs [2] (**Confirmed** as Microsoft's guidance).
2. Alert when a service principal assigns itself a directory role, when credentials are added to an application, and on "Add service principal credentials" audit events [3] [4] (**Confirmed** as Huntress's guidance).
3. Restrict who and what can add credentials to applications with application management policies [3] (**Confirmed** as Huntress's guidance).
4. For an affected vendor app: disable it, do not delete it first (keep the evidence), then review service-principal sign-ins back to 1 October, consent grants, role and Conditional Access changes [2] (**Confirmed** as Microsoft's guidance).
5. Turn on Microsoft Graph activity logs before you need them, and baseline each vendor app's user agent and cadence [4] (**Confirmed** as Huntress's guidance).

Scope and method

This brief covers the compromise of ConnectWise Cloud Backup's application credentials, the activity in customer tenants, the attribution and the vendor's response through the last advisory update on 4 November 2026. It does not repeat the October 2026 roundup in PHP2Shell and October 2026 [17] or the Chinese state-actor record in Threat Actors: China [15]. The Year 2026 in Intrusions [18] and Major Cloud Security Incidents [19] summarize this event in a paragraph each; this brief is the home study for it. Tradecraft is described at advisory level. Indicators are defanged. All times are UTC.

Grade	Meaning in this study
Confirmed	Stated in a primary opened for this study by the party that did or saw it: the ConnectWise advisory, Microsoft Threat Intelligence, Huntress's first-party telemetry, the CISA KEV catalog
Reported	Known through journalism or a secondary account of a primary
Demonstrated	Shown by this study's own check of data (the library's ATT&CK, CAPEC and D3FEND files)
Inferred	This study's own reasoning from cited facts, labelled where it appears

How the vendor-tenant credential was first obtained is not public; on 20 October ConnectWise said third-party specialists were still investigating initial access [1] (**Confirmed**).

Part 1: what happened

Date and time (UTC)	Event	Sources	Grade
31 Oct 2024	Microsoft profiles Storm-0940: active since at least 2021, targeting think tanks, government, NGOs, law firms and the defense industrial base, using credentials from the CovertNetwork-1658 (Quad7) password spray	[6]	Confirmed
28 May 2025	ConnectWise discloses ScreenConnect activity tied to a nation-state actor known for intelligence collection; a different product, and no link to Storm-0940 is stated	[1]	Confirmed
September 2026	Storm-0940 is using ARTEX against organizations from as early as September 2026, per Microsoft	[2]	Confirmed
10 to 14 Oct	Password spray from 144.172.64[.]99 against 327 accounts at eight organizations: over 151,000 failed logons, a peak of about 2,900 failures a minute on 11 Oct, nearly 98% lockouts, no successful authentication	[2]	Confirmed
13 to 14 Oct	Huntress sees a spray against four law-firm tenants from 144.172.64[.]128; two lockouts, no successful user sign-ins	[3]	Confirmed
14 Oct	Cybersecurity Dive reports ConnectWise "first detected suspicious activity" this day; neither ConnectWise's advisory nor Microsoft's post gives this date	[12]	Reported
15 Oct, from 01:58	ConnectWise Cloud Management service principals assign themselves directory roles, mostly Exchange Administrator, in about 50 tenants; Huntress has not confirmed whether this was vendor automation	[3]	Confirmed
15 Oct, 03:44 and 03:48	In one tenant the Cloud Management MS Teams app assigns itself Global Administrator; a script then makes nine credential changes to two other apps, six succeeding	[3]	Confirmed
15 Oct, 06:13 to 08:34	The Cloud Backup app authenticates from 144.172.64[.]128 and obtains Graph tokens; last confirmed successful sign-in at 08:44	[3]	Confirmed
15 Oct, 09:25 to 14:20	A targeted second wave hits 16 Huntress-protected tenants in policy, national security, trade and critical minerals; attempts fail where the service principal is absent	[3]	Confirmed
16 Oct	Huntress publishes; unauthorized sign-ins confirmed in 162 tenants as of 19:00	[3]	Confirmed
16 Oct, 17:47	ConnectWise publishes its advisory, investigating attempts of unauthorized access; indicator 144.172.64[.]128 and two Python user agents	[1]	Confirmed
17 Oct, 05:01	ConnectWise confirms "unauthorized access to application identities" and shuts off application access	[1]	Confirmed
17 Oct, 07:00	Seven application identities disabled (a later update gives 05:00 as the start of mitigations)	[1]	Confirmed
17 Oct	Certificates for affected connections revoked across all users; an unnamed incident response firm engaged. Huntress: almost 1,000 Entra tenants saw sign-ins from 144.172.64[.]128, over 300 succeeding	[1] [3]	Confirmed
18 Oct	SaaS Security and Cloud Management taken offline alongside Cloud Backup; at 18:45, indicators 144.172.64[.]99 and 144.172.64[.]60 added	[1]	Confirmed

Date and time (UTC)	Event	Sources	Grade
19 Oct	Full reset of all accounts and credentials in the affected environment completed. Huntress: two tenants with post-compromise activity among more than 10,000 reviewed	[1] [3]	Confirmed
20 Oct	Initial access still under investigation by third-party specialists	[1]	Confirmed
21 Oct	Microsoft assesses that Storm-0940 was responsible, using ARTEX. Phased restoration begins at 12:45. At 22:00 ConnectWise says it "appears" a China state-aligned group was responsible	[1] [2]	Confirmed
22 Oct	CEO Manny Rivelo says AI lets attackers test connections at "machine speed"	[12]	Reported
26 Oct	A Monday onboarding target slips, with no new date. Huntress publishes its follow-up analysis	[1] [4]	Confirmed
28 Oct	Restoration of M365 backups begins through a new app, "ConnectWise Cloud Backup for M365"; partners must reset passwords and re-authorize each tenant	[1]	Confirmed
30 Oct	Phases 1 and 2 of four complete; archives "encrypted, isolated, and preserved"	[1]	Confirmed
3 to 4 Nov	Backup Health, export jobs and Marketplace APIs restored; SaaS Security and Cloud Automation restored (reconnection needed); billing and some notifications still in progress at the last update (4 Nov, 18:55)	[1]	Confirmed
6 Nov	Microsoft reports Storm-3358, a financially motivated, Cambodia-based cluster, also using ARTEX against financial organizations	[7]	Confirmed

Discrepancies in the record

- **Tenant counts.** More than 2,250 tenants targeted with sign-in attempts (Microsoft) [2]; 162 with confirmed sign-ins and more than 300 successful sign-in tenants among almost 1,000 (Huntress) [3]. These measure different things; none is a count of compromised tenants (**Inferred**).
- **Four or three app IDs.** Microsoft refers to four application credentials, but its hunting queries list three IDs; Huntress lists seven app identities [2] [3] (**Confirmed**).
- **Mitigation start.** 07:00 on 17 October in one ConnectWise update, 05:00 in a later one [1] (**Confirmed**).
- **The 14 October date** rests on Cybersecurity Dive alone [12] (**Reported**). The library's TIMELINE.md and PHP2Shell and October 2026 state it as fact [17].
- **The 2,900 figure** is Microsoft's peak of failed spray logons on 11 October, not a sign-in rate against tenants, and the spray hit 327 accounts at eight organizations, not "327 organizations" as Cybersecurity Dive has it [2] [12] (**Confirmed** for Microsoft's figures). PHP2Shell and October 2026 repeats the sign-in reading [17].

Part 2: the intrusion record

The credential. The compromised secret was an application credential (a client assertion credential, in Huntress's words) held in the vendor's own tenant [3] (**Confirmed**). ConnectWise's own wording moved from "application identities" on 17 October to "application credentials" on 28 October [1] (**Confirmed**). With these credentials, the attacker could authenticate as ConnectWise's multi-tenant apps into tenants that had consented to them and received Graph tokens carrying the permissions those customers had granted [2] [3] (**Confirmed**). Because this was app-only authentication, user MFA did not apply; Todyl, quoted by BleepingComputer, put it plainly: no user signed in [10] (**Reported**).

Before the credential. The sprays in Part 1 came from the same 144.172.64[.]0/24 range as the later app sign-ins and failed against users [2] [3] (**Confirmed**). Microsoft calls 144.172.64[.]99 Storm-0940 infrastructure [2]; Huntress notes that Microsoft does not say what links the spray to Storm-0940 [4] (**Confirmed**).

Privilege and persistence, 15 October. The ConnectWise Cloud Management MS Teams app assigned itself Global Administrator in one tenant, and a script added client secrets, valid into 2028, to two other apps, an MSP management app and Huntress's own; six of nine changes succeeded [3] (**Confirmed**). Across about 50 tenants, Cloud Management service principals took directory roles, mostly Exchange Administrator; whether that was ConnectWise's own automation is unresolved [3] (**Confirmed**).

Follow-on activity. Microsoft saw application credential additions, changes to identities, groups and privileged roles, Graph reconnaissance, and bulk secret reads across multiple Azure Key Vaults with key enumeration and a key-unwrap operation [2] (**Confirmed**). In the two tenants Huntress reviewed, it found no mailbox or file manipulation and no user or policy changes, and summarized the state as "tokens issued, nothing visible taken" [3] (**Confirmed**).

Indicators. Beyond the three 144.172.64[.]0/24 addresses and the Python-urllib/3.12 and python-requests/2.31 user agents in Part 1 [1] [2], Microsoft adds transient VPN addresses 187.15.88[.]186, 187.15.90[.]217 and 187.15.89[.]186 for 15 and 16 October [2] (**Confirmed**).

The AI element. ARTEX is an open-source, multi-agent LLM penetration-testing framework with a Go back end and a Next.js front end that can use any AI model [2]. Microsoft says Storm-0940 used it to speed scanning, password spraying and OAuth application abuse [2] (**Confirmed** as Microsoft's account). Huntress rates its confidence that an LLM was involved low-to-medium on its own telemetry and medium-to-high with Microsoft's attribution [4] (**Confirmed**).

Part 3: who and why

Microsoft "assesses" that Storm-0940 was responsible. It describes Storm-0940 as China-state aligned, with no known industry aliases, active since 2021, and gives no confidence level [2] (**Confirmed**). Its 2024 profile ties Storm-0940 to credentials harvested by the CovertNetwork-1658 (Quad7) password spray, sometimes used the same day [6] (**Confirmed**).

ConnectWise does not name Storm-0940. Its 21 October update says it "appears that a China state-aligned group was responsible", citing Microsoft's threat intelligence, and that the group used an openly available agentic AI framework [1] (**Confirmed**).

Huntress says its observations are consistent with Microsoft's account but do not independently verify the attribution or the ARTEX use, and notes that Microsoft does not say how it identified ARTEX [4] [5] (**Confirmed**).

ARTEX is not a fingerprint. Microsoft says many actors across multiple regions use ARTEX, so its use alone does not indicate Storm-0940 [2]. By 6 November Microsoft was reporting Storm-3358, a financially motivated Cambodia-based cluster, using it against financial organizations, mainly in Southeast Asia [7] (**Confirmed**).

Why. Microsoft lists Storm-0940's targets as aerospace and defense, automotive, chemicals, energy, financial services, government, legal, manufacturing, media, military, semiconductor, software, technology, and think tanks and non-profits [2] (**Confirmed**). The second wave on 15 October went to policy, national security, trade and critical-minerals tenants [3] (**Confirmed**). That profile reads as intelligence collection rather than extortion (**Inferred**). No government advisory or attribution was found in a domain-restricted search [13] (**Reported**; search not exhaustive).

Lineage. Abuse of MSP trust has a long China-nexus record: APT10's Operation Cloud Hopper and Silk Typhoon's use of IT-provider credentials sit in Threat Actors: China, which also lists C0055 Quad7 Activity against Storm-0940 [15] (**Confirmed** as the library records it). Credentials added to service principals and OAuth apps were also how the SolarWinds SUNBURST actor held cloud access in 2020 [16] (**Confirmed** as the library records it).

Part 4: impact and response

Victims and sectors. The victims are MSPs and their clients using the Cloud Backup integration; the total count and the extent of any data theft remain unclear [10] (**Reported**). Across the wider Storm-0940 campaign, Microsoft says most targeting failed, but the actor achieved privileged cloud persistence at many organizations and Microsoft found follow-on activity in multiple customer environments [2] (**Confirmed**). Todyl analyzed nine tenants and found sign-in activity only [10] (**Reported**). ConnectWise says it cannot determine whether an individual partner or customer tenant was affected, and that each needs review [1] (**Confirmed**).

The vendor. The containment and restoration steps are in Part 1 [1] (**Confirmed**). ConnectWise warned that previously issued tokens may stay usable until they expire, and that disabling the apps does not reverse changes already made inside a tenant [1] (**Confirmed**). It says backup archives remain encrypted and isolated with no indication of compromise, and that it has no indication other ConnectWise products, services or offerings are impacted [1] (**Confirmed** as ConnectWise states; not independently verified).

Microsoft says the activity did not result from a compromise of, or a vulnerability in, Microsoft systems, products or services [2] (**Confirmed**). Its Defender detections included "Application self-assigned Global Administrator role" and a Key Vault anomaly alert on bulk secret reads [2] (**Confirmed**).

Government and regulator record. No CISA, FBI, NCSC, ASD or CCCS advisory on this incident was found, and the news coverage opened mentions no government response [11] [12] [13] (**Reported**; not checked exhaustively). Regulator filings: not checked.

KEV. No CVE applies, so no KEV date applies. ConnectWise's KEV entries are all ScreenConnect: CVE-2024-1709 (added 2024-02-22), CVE-2025-3935 (2025-06-02), CVE-2024-1708 (2026-04-28) and CVE-2026-84869 (2026-09-11) [8] (**Confirmed**).

Part 5: the defender and vulnerability-management view

No scanner would have found this: there was no vulnerable version to patch, only a standing high-privilege grant to a third party whose credential lived in the vendor's tenant (**Inferred**). A vulnerability-management program should treat multi-tenant app consents as exposures with an owner, a privilege rating and a review date, alongside the CVE queue (**Inferred**).

Control	Where it meets the record
Least-privilege consent for vendor apps	The apps held high privileges [2], reportedly including Directory.ReadWrite.All [9]
Alert on role self-assignment by a service principal	Global Administrator taken at 03:44 and 03:48 on 15 Oct [3]; Microsoft's matching Defender alert [2]
Alert on credentials added to apps; restrict with app management policies	Secrets valid to 2028 planted on two apps [3]
Service-principal sign-in logs filtered by application ID	Huntress's effective detection, with the audit events "Add member to role", "Update application" and "Add service principal credentials" [3]
Graph activity logs	Directory reads leave no audit record without them [3] [4]
Key Vault anomaly detection	Bulk secret reads and key enumeration [2]
Disable, do not delete	Preserves evidence; deletion first loses it [2] [3]

Huntress adds alerts for a service principal that deletes itself or takes Privileged Role Administrator [4] (**Confirmed**).

What is overstated and what is understated

- **Overstated:** the tenant counts, the 2,900 figure, "327 organizations" and the 14 October date, as set out under Discrepancies in the record; TechCrunch's "thousands of companies" [11]; and any framing of this as an AI-led breach, when ARTEX sped up known techniques and Huntress cannot verify its use [4] (**Inferred** from the cited record).
- **Understated:** secrets planted on other apps outlive the vendor's credential rotation [3]; tokens issued before the shutoff may stay valid until expiry [1]; Huntress sees only its own customers, so 162 is a floor [3]; and the number of compromised customers is unknown [2] (**Inferred** from the cited record).

MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0 Enterprise, CAPEC and D3FEND. Names and tactics come from the library's `data/attack/technique_profiles.jsonl`, `groups.jsonl`, `software.jsonl`, `campaigns.jsonl` and `technique_to_d3fend.jsonl` [14] (**Demonstrated**). Microsoft lists ten technique ids for this activity [2]; Password Spraying is this study's addition from Microsoft's narrative. No industrial system is involved, so no ATT&CK for ICS techniques apply.

Groups, software and campaigns

ATT&CK has no group object for Storm-0940 and no software object for ARTEX in the library's data [14] (**Demonstrated**), so none is bound. One object is related, not bound:

Object	ATT&CK id	Relationship to this record
Quad7 Activity	C0055	Campaign (Aug 2023 to Aug 2025) for the CovertNetwork-1658 botnet; ATT&CK cites Microsoft's Storm-0940 report [6] [14]. Lineage only; no source ties Quad7 infrastructure to the ConnectWise activity

ATT&CK Enterprise techniques

ID	Name	Tactic(s)	Dated event or report	Sources
T1595	Active Scanning	Reconnaissance	ARTEX used to speed scanning from September 2026 (Microsoft, 21 Oct 2026)	[2]
T1110.003	Password Spraying	Credential Access	Spray from 144.172.64[.]99, 10 to 14 Oct 2026; law-firm spray, 13 to 14 Oct. Id is this study's mapping (**Inferred**)	[2] [3]
T1195	Supply Chain Compromise	Initial Access	A vendor's multi-tenant app credential used to enter customer tenants, 15 Oct 2026	[2]
T1199	Trusted Relationship	Initial Access	Access rode on permissions customers had granted the vendor app, 15 Oct 2026	[2] [3]
T1078.004	Cloud Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	The Cloud Backup app authenticated from 144.172.64[.]128, 06:13 to 08:44 on 15 Oct 2026	[2] [3]
T1528	Steal Application Access Token	Credential Access	Graph tokens obtained, 06:13 to 08:34 on 15 Oct 2026	[2] [3]
T1098.003	Additional Cloud Roles	Persistence, Privilege Escalation	Global Administrator self-assigned at 03:44 and 03:48 on 15 Oct 2026; directory roles in about 50 tenants from 01:58 (vendor automation not ruled out)	[2] [3]
T1098.001	Additional Cloud Credentials	Persistence, Privilege Escalation	Client secrets valid to 2028 added to two other apps, 15 Oct 2026	[2] [3]
T1087.004	Cloud Account	Discovery	Graph reconnaissance of identities and groups (Microsoft, 21 Oct 2026)	[2]
T1580	Cloud Infrastructure Discovery	Discovery	Key enumeration across Azure Key Vaults (Microsoft, 21 Oct 2026)	[2]
T1555.006	Cloud Secrets Management Stores	Credential Access	Bulk secret reads across multiple Key Vaults and a key-unwrap operation (Microsoft, 21 Oct 2026)	[2]

Fit notes (**Inferred**): T1195 and T1199 both stand because Microsoft lists both; the record supports Trusted Relationship more directly, since no product code was altered. The role self-assignments in about 50 tenants are bound under T1098.003 with Huntress's caveat that they may be vendor automation.

CWE and CAPEC

No CVE applies, so no CNA has assigned a CWE, and this study binds none [8]. CAPEC entries the library relates to this study's techniques that meet the record [14]:

CAPEC	Name	Via	Where it meets the record
CAPEC-565	Password Spraying	T1110.003	The 10 to 14 Oct spray [2]
CAPEC-21	Exploitation of Trusted Identifiers	T1528	Graph tokens issued to a trusted vendor identity [3] (**Inferred**)
CAPEC-169	Footprinting	T1595	ARTEX-driven scanning [2] (**Inferred**, partial fit)

CAPEC-438, CAPEC-439 and CAPEC-446, which the library relates to T1195, are left out: they describe tampering with a product during manufacture or distribution, and nothing in the record shows that.

D3FEND countermeasures

D3FEND countermeasure	Techniques the library maps it to (from this study)	Where it meets the record
Credential Revocation	T1098.001, T1528, T1110.003	ConnectWise revoked certificates for affected connections [1]
Credential Rotation	T1098.001, T1528, T1110.003	The full credential reset of 19 Oct [1]
Reissue Credential	T1098.001, T1528, T1110.003	Re-authorization of each tenant through the new app [1]
Credential Compromise Scope Analysis	T1098.001, T1528, T1110.003	The per-tenant review ConnectWise and Microsoft require [1] [2]
Token Binding	T1528	Would limit reuse of tokens issued before the shutoff (**Inferred**) [1]
User Account Permissions	T1078.004, T1098.003, T1087.004	Least privilege for multi-tenant app grants [2]
Domain Account Monitoring	T1098.003	Alerts on role self-assignment [2] [3]
Account Locking	T1078.004, T1098.003, T1087.004	ConnectWise disabled seven application identities at 07:00 on 17 Oct [1] (**Inferred** fit)
User Geolocation Logon Pattern Analysis	T1199, T1098.001, T1110.003	Sign-ins from the 144.172.64[.]0/24 range and transient VPN addresses [2] (**Inferred**)

See the D3FEND Reference.

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, `navigator/library-layers/connectwise-storm-0940-2026.json` (open in Navigator), listed on the Navigator layers page. It is pinned to ATT&CK v20, domain `enterprise-attack`. A score of 100 means Microsoft lists the id and a primary describes the dated behavior; 60 means a primary describes the behavior and the id is this study's mapping (T1110.003 only). Each comment names the event and the source numbers.

Cross-cutting themes

- **Standing consent is standing exposure.** The same pattern of credentials added to apps and service principals runs from SolarWinds SUNBURST [16] to this incident; the 2026 difference is that the foothold was a vendor's own app (**Inferred**).
- **MSPs remain a force multiplier.** A vendor's application credentials were used to attempt sign-ins to more than 2,250 tenants [2], the economics that drew APT10 to MSPs in 2017 [15] (**Inferred**).
- **AI changes tempo, not technique.** Every step maps to an existing ATT&CK technique; what ARTEX changed, per Microsoft, was speed [2] (**Inferred**). See AI Threats in the Cybersecurity Industry.
- **Logs decide what can be known.** Without Graph activity logs, no one can say whether data was read [3] (**Confirmed**).

Sources

Sources 1 to 17 were opened on 11 November 2026, and sources 1 to 6 were reopened on 12 November 2026. Sources 18 and 19 were opened on 12 November 2026.

#	Source	URL	Opened	Grade
1	ConnectWise Trust Center, advisory "Cloud Backup (formerly known as SkyKick) Service Interruption", first published 16 Oct 2026 17:47 UTC, last updated 4 Nov 2026 18:55 UTC (same page carries the 28 May 2025 ScreenConnect advisory)	connectwise.com/company/trust/advisories	2026-11-11	Confirmed
2	Microsoft Threat Intelligence, AI-driven, large-scale nation-state campaign using ARTEX enables supply chain compromise, 21 Oct 2026 (updated after publication)	microsoft.com/en-us/security/blog/2026/10/21/storm-0940-...	2026-11-11	Confirmed
3	Huntress, ConnectWise (SkyKick) Vendor Credentials Abused in M365 Attacks, 16 Oct 2026, updated 17, 19 and 27 Oct	huntress.com/blog/vendor-credential-enables-unauthorized-access	2026-11-11	Confirmed
4	Huntress, AI, Scripts, Operator: Inside the ConnectWise Attack, 26 Oct 2026	huntress.com/blog/connectwise-attack-ai	2026-11-11	Confirmed
5	Huntress threat library, Storm-0940	huntress.com/threat-library/threat-actors/storm-0940	2026-11-11	Confirmed
6	Microsoft Threat Intelligence, Chinese threat actor Storm-0940 uses credentials from password spray attacks from a covert network, 31 Oct 2024	microsoft.com/en-us/security/blog/2024/10/31/chinese-threat-actor-storm-0940-...	2026-11-11	Confirmed
7	Microsoft Threat Intelligence, ARTEX abuse expands as cybercriminals target financial sector, 6 Nov 2026	microsoft.com/en-us/security/blog/2026/11/06/artex-abuse-expands-...	2026-11-11	Confirmed
8	CISA, Known Exploited Vulnerabilities catalog JSON, version 2026.11.10	cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
9	The Record (Recorded Future News), report on ConnectWise suspending Cloud Backup, 19 Oct 2026	therecord.media/connectwise-suspends-cloud-backup-service-supply-chain-attack	2026-11-11	Reported
10	BleepingComputer, report on Microsoft 365 tenant breaches through the ConnectWise integration, 17 Oct 2026, updated 18 Oct	bleepingcomputer.com/news/security/hackers-breach-microsoft-365-tenants-...	2026-11-11	Reported
11	TechCrunch (Zack Whittaker), report headlined on "thousands of companies", 22 Oct 2026	techcrunch.com/2026/10/22/chinese-hackers-spied-on-thousands-...	2026-11-11	Reported
12	Cybersecurity Dive (David Jones), report on the China-nexus attack on ConnectWise Cloud Backup, 22 Oct 2026	cybersecuritydive.com/news/china-nexus-actor-attack-connectwise-cloud-backup/	2026-11-11	Reported
13	CyberScoop (Matt Kapko), report on Microsoft's Storm-0940 attribution, 21 Oct 2026	cyberscoop.com/microsoft-attributes-connectwise-supply-chain-attack-china-storm-0940/	2026-11-11	Reported
14	TeamStarWolf library data: `data/attack/technique_profiles.jsonl`, `groups.jsonl`, `software.jsonl`, `campaigns.jsonl`, `technique_to_d3fend.jsonl` (ATT&CK v20.0), and the `mitre/` page tree	github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	2026-11-11	Demonstrated
15	TeamStarWolf, Threat Actors: China	/case-studies/THREAT_ACTORS_CHINA.md	2026-11-11	Confirmed
16	TeamStarWolf, SolarWinds SUNBURST case study	/case-studies/SOLARWINDS_SUNBURST.md	2026-11-11	Confirmed
17	TeamStarWolf, PHP2Shell and October 2026, and TIMELINE.md	/case-studies/PHP2SHELL_OCTOBER_2026.md	2026-11-11	Confirmed
18	TeamStarWolf, The Year 2026 in Intrusions: A Dated Record	/case-studies/CHRONICLE_2026.md	2026-11-12	Confirmed
19	TeamStarWolf, Major Cloud Security Incidents: The Public Record, 2011 to 2026	/case-studies/CLOUD_SECURITY_INCIDENTS.md	2026-11-12	Confirmed

Not opened, so not cited as sources: Dark Reading's coverage (HTTP 403), and the further coverage the Intelligence Hub feed indexes (The Register, SecurityWeek, The Hacker News, Infosecurity Magazine, Security Affairs, the GTIG and Check Point Research ARTEX posts).

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Threat Actors: China, The Year 2026 in Intrusions, Major Cloud Security Incidents, Able2Shell and the RMM Attack Surface, PHP2Shell and October 2026, SolarWinds SUNBURST, AI Threats in the Cybersecurity Industry, Timeline
- Threat Actors, Malware Families, Notable Incidents
- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Identity and Access Management Reference, SaaS Security Reference, Cloud Attack Reference, Supply Chain Security Reference, AI Security Reference
- Vulnerability Management Reference, Vulnerability Prioritization Reference
- Campaigns: C0055 Quad7 Activity
- Techniques: T1595 Active Scanning, T1110.003 Password Spraying, T1195 Supply Chain Compromise, T1199 Trusted Relationship, T1078.004 Cloud Accounts, T1528 Steal Application Access Token, T1098.003 Additional Cloud Roles, T1098.001 Additional Cloud Credentials, T1087.004 Cloud Account, T1580 Cloud Infrastructure Discovery, T1555.006 Cloud Secrets Management Stores
- CAPEC: CAPEC-565, CAPEC-21, CAPEC-169
- Navigator layers, including this study's layer, connectwise-storm-0940-2026.json
- The Team Star Wolf Intelligence Hub
- All case studies